root@informatika-unsil:~# ./zero-trust.sh

KEAMANAN INFORMASI · MATERI PASCA-UTS

Zero Trust Security Architecture

Never trust, always verify · NIST SP 800-207 · Microsegmentation · Defense in depth

Saki · Informatika Universitas Siliwangi

pdp-monitor LIVE

```
[ OK ] pdp: kebijakan dimuat
[ OK ] mfa: sesi dosen valid
[DENY] lab-srv → db:3306
[WARN] login dari 2 negara
[ OK ] sesi dicabut, step-up MFA
[INFO] cek ulang setiap akses
$ _
```

PERTANYAAN #1 BAGIAN 01 · NEVER TRUST, ALWAYS VERIFY

Penyerang login ke Sintesys dengan password dan kode MFA yang sah. Bagaimana sistem tahu ia bukan dosen pemiliknya?

Selain kredensial, apa lagi yang bisa diperiksa?

$ ./01_prinsip --perimeter

Castle-and-moat vs. Zero Trust

ASPEK	CASTLE-AND-MOAT	ZERO TRUST
Dasar kepercayaan	Lokasi: di dalam jaringan berarti dipercaya	Identitas, perangkat, dan konteks
Kapan diperiksa	Sekali, di pintu masuk	Setiap permintaan akses
Luas akses	Seluruh zona yang terbuka	Satu resource, satu sesi
Asumsi	Ancaman datang dari luar	Assume breach: penyerang mungkin sudah di dalam

$ ./01_prinsip --never-trust

Never trust, always verify dalam tiga prinsip kerja

01

Verify explicitly

Setiap akses diautentikasi dan diotorisasi dengan semua data yang ada.

DI KAMPUS

Membuka Sintesys dicek: akun, MFA, perangkat, lokasi.

02

Least privilege

Hak akses secukupnya, untuk waktu secukupnya (just-in-time).

DI KAMPUS

Dosen hanya melihat nilai kelas yang ia ampu, bukan seluruh prodi.

03

Assume breach

Rancang seolah penyerang sudah di dalam: batasi jangkauan, catat semuanya.

DI KAMPUS

Server lab yang jebol tetap tak bisa menyentuh DB Sintesys.

KASUS NYATA · TRANSPORTASI DARING · SEPTEMBER 2022

Uber: MFA sudah ada, tetapi setelah lolos semuanya dipercaya

01 Password kontraktor dicuri malware di perangkat pribadinya, lalu dijual di dark web.

02 Push MFA dikirim berulang kali sampai disetujui (MFA fatigue).

03 Penyerang dilaporkan menemukan kredensial admin di skrip pada network share.

04 Dari satu akun, penyerang menjangkau banyak sistem internal, termasuk Slack dan G Suite.

// PELAJARAN

Lolos MFA sekali bukan izin untuk semua resource.

Unmanaged device perlu dibatasi.

Phishing-resistant MFA mengurangi MFA fatigue.

Kredensial tidak disimpan di dalam skrip.

PERTANYAAN #2 BAGIAN 02 · NIST SP 800-207

Jika setiap akses diperiksa, siapa yang memutuskan dan siapa yang menegakkan?

Firewall memeriksa paket. Siapa yang memeriksa identitas, perangkat, dan konteks?

$ ./02_nist --tenets

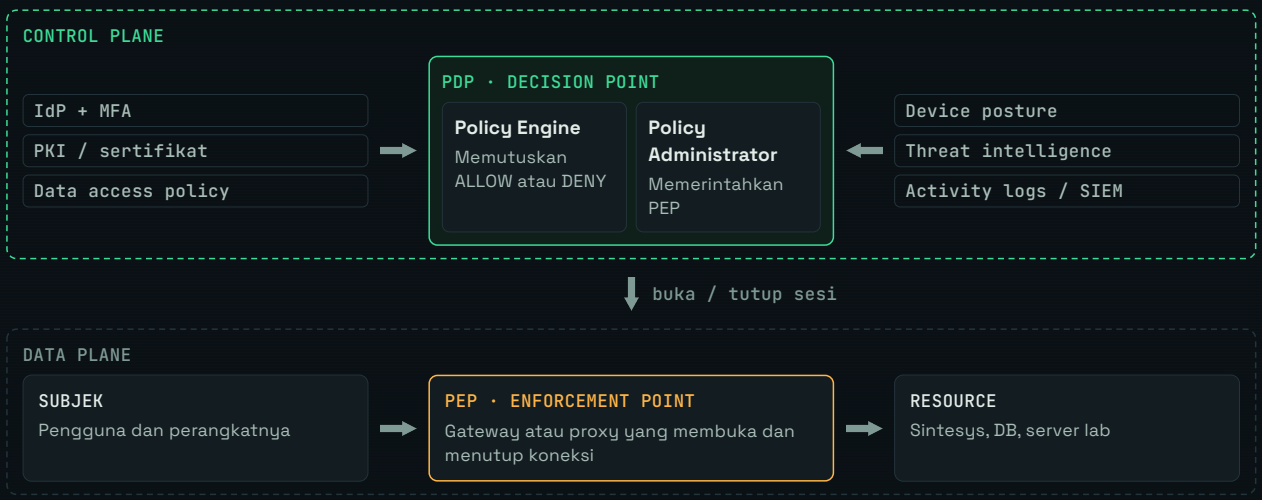
NIST SP 800-207: tujuh tenet Zero Trust

#	TENET	DI JARINGAN KAMPUS
1	Semua data dan layanan komputasi adalah resource	Sintesys, DB, server lab, printer jaringan
2	Komunikasi diamankan di mana pun lokasinya	Lalu lintas di dalam VLAN 30 pun dienkripsi
3	Akses diberikan per sesi, per resource	Login Sintesys tidak otomatis membuka DB
4	Akses ditentukan oleh kebijakan dinamis	Identitas, kondisi perangkat, lokasi, waktu
5	Integritas dan security posture aset dipantau	Laptop tanpa patch terdeteksi dan dibatasi
6	Autentikasi dan otorisasi ditegakkan sebelum akses	Diulang saat sesi lama atau konteks berubah
7	Data sebanyak mungkin dikumpulkan untuk perbaikan	Access log dipakai untuk tuning kebijakan

INTINYA Lokasi dalam jaringan tidak pernah menjadi alasan untuk dipercaya.

$ ./02_nist --komponen

Komponen logis menurut NIST SP 800-207



$ ./02_nist --trust-algorithm

Trust algorithm dalam lima permintaan

SUBJEK · PERANGKAT	KONTEKS · JAM AKSES 07.00–21.00	KEPUTUSAN PDP
Dosen · laptop kampus (managed)	Ruang dosen, 10.00	ALLOW · modul nilai kelasnya
Dosen · laptop pribadi, OS belum di-patch	Dari rumah, 22.30 (di luar jam akses)	LIMITED · hanya baca, step-up MFA
Akun dosen · unmanaged device	Impossible travel: luar negeri, 10 menit setelah login di Tasikmalaya	DENY · sesi dicabut, alert ke tim
Server lab	Koneksi ke DB Sintesys :3306	DENY · tidak ada kebutuhan
Admin · laptop admin + security key FIDO2	Ada tiket perubahan, 14.00	ALLOW · akses DB 2 jam (just-in-time)

DUA GAYA Criteria-based: semua syarat wajib terpenuhi · Score-based: trust score melewati threshold

PERTANYAAN #3 BAGIAN 03 · MICROSEGMENTATION

Server lab di VLAN 30 diretas lewat tugas praktikum. Apa yang menghalanginya menyentuh DB Sintesys di zona yang sama?

Firewall antar-zona dari pertemuan 9 tidak memeriksa lalu lintas di dalam satu zona.

$ ./03_microseg --vlan30

Dari VLAN ke microsegmentation

SEGMENTASI · PERTEMUAN 9

VLAN 30 · 10.30.0.0/24

sintesys .10 | db-sintesys .20 | lab .30

Batas ada di tepi zona. Di dalamnya, semua host saling terjangkau.

MICROSEGMENTATION

sintesys → db-sintesys:3306	ALLOW
lab → db-sintesys	DENY
lab → sintesys	DENY

Batas melekat pada setiap workload, sekecil satu server.

YANG DIATUR

Lalu lintas east-west antar-workload, bukan hanya north-south.

DASAR ATURAN

Identitas atau label workload, bukan alamat IP.

ALAT

Host firewall, hypervisor, Kubernetes NetworkPolicy, security group.

PERTANYAAN #4 BAGIAN 04 · DEFENSE IN DEPTH

Jika Zero Trust sudah diterapkan, apakah firewall, IDS, dan backup masih diperlukan?

Bayangkan PDP salah konfigurasi, atau IdP kampus sedang diserang.

$ ./04_defense --lapisan

Defense in depth: lapisan dan jenis kontrol

LAPISAN	PREVENTIVE	DETECTIVE	CORRECTIVE
L1 · SDM	Security awareness training	Access review berkala	Incident response plan
L2 · PERIMETER	Firewall, VPN + MFA	IDS di gateway	IPS memblokir sumber
L3 · INTERNAL	VLAN, microsegmentation	Sensor IDS zona server	Isolasi segmen terinfeksi
L4 · HOST	Patch, hardening	Endpoint Detection and Response	Reimage host
L5 · APLIKASI	Validasi input, WAF	Log aplikasi	Hotfix, cabut sesi
L6 · DATA	Enkripsi, kontrol akses	Alert eksfiltrasi data	Restore dari backup

PRINSIP Bila satu kontrol gagal, kontrol lain dengan jenis berbeda masih bekerja.

$ ./04_defense --swiss-cheese

Satu serangan menembus lapisan demi lapisan

01
Email phishing ke dosen
L1 · security awareness training
LOLOS

→

02
Malware jenis baru di laptop
L4 · EDR
LOLOS

→

03
Login Sintesys dari laptop yang sama
PDP · perangkat terdaftar, konteks normal
LOLOS

→

04
Mencoba langsung ke DB Sintesys
L3 · microsegmentation
TERTAHAN

→

05
Eksfiltrasi data nilai lewat Sintesys
L6 · alert eksfiltrasi data
TERDETEKSI

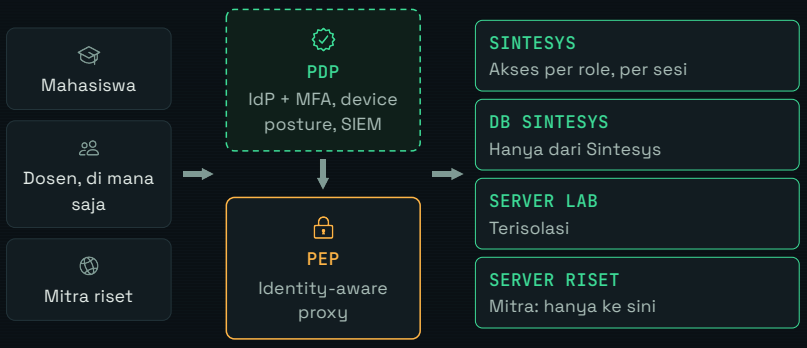
SWISS CHEESE MODEL
Tiap lapisan berlubang; insiden terjadi saat lubangnya sejajar.

ZERO TRUST MENJAWAB
Siapa boleh mengakses apa, kapan, dari perangkat apa.

DEFENSE IN DEPTH MENJAWAB
Jika satu kontrol gagal, apa yang menahan berikutnya.

$ ./05_penutup --arsitektur

Jaringan kampus dengan Zero Trust



JAWABAN PERTANYAAN #1

Penyerang dengan password dan kode MFA curian kini:

01 Ditolak karena memakai unmanaged device (PDP).

02 Sesinya dicabut bila konteks janggal (trust algorithm).

03 Jika lolos, hanya satu aplikasi yang terbuka (PEP).

04 DB tetap tak terjangkau (microsegmentation).

$ ./05_penutup --aplikasi

Untuk aplikasi

NIST SP 800-207	DI APLIKASI WEB
PEP	API gateway atau middleware yang mencegat setiap request
PE / PA	Modul policy: login, menerbitkan dan mencabut token, ALLOW/DENY
Resource	Service dan endpoint API
Data sources	Data user, role, registered device, dan audit log

SHORT-LIVED TOKEN

Access token hanya beberapa menit; refresh token bisa dicabut saat logout.

WORKLOAD IDENTITY

Service lain diverifikasi lewat tokennya, bukan karena satu jaringan.

OBJECT-LEVEL AUTHORIZATION

Role saja tidak cukup: dosen A tidak boleh mengubah nilai kelas dosen B (IDOR).

DEFENSE IN DEPTH

Service tetap memverifikasi token walau request datang dari gateway.

$ ./05_penutup --ringkasan

Ringkasan pertemuan

NEVER TRUST	Lokasi jaringan bukan alasan untuk dipercaya; setiap akses diperiksa.
NIST SP 800-207	PDP memutuskan, PEP menegakkan, berdasar identitas, perangkat, konteks.
MICROSEGMENTATION	Batas per workload, berbasis label, mengatur lalu lintas east-west.
DEFENSE IN DEPTH	Lapisan beragam: preventive, detective, dan corrective saling menutup lubang.
ARSITEKTUR	Zero Trust melengkapi firewall, IDS, dan VLAN, bukan menggantikannya.

root@informatika-unsil:~# exit

Sesi tanya jawab

BACAAN LANJUTAN

NIST SP 800-207 · Zero Trust Architecture

CISA ZTMM 2.0 · Zero Trust Maturity Model

Ward & Beyer (2014) · BeyondCorp: A New Approach to Enterprise Security

logout · session revoked by policy.